POOJA KIRAN | SECURITY ENGINEERING

Non-Executing Security Analysis of AI Model Supply-Chain Artifacts

Provenance, Serialization, Impersonation, and Repository Risk Inspection

Source inventory: e3b100e6768ff37391bf780a43783ee5ed44b6d6

Test snapshot: 251a7b90fd60fa1884c643adda9d96cd7801abe6

CI run 37163168715 | initiated 2026-10-03 UTC | MIT

https://github.com/poojakira/hf-model-provenance-scanner

241
tests passed in cited CI

75.67%
statement coverage, same CI job

33 / 33
committed adversarial fixtures, separately reproduced

0 / 4
actionable findings / committed benign samples

CONTRIBUTION

- A primarily non-executing model-artifact security scanner combining static code analysis, symbolic and taint-style inspection, binary-format parsing, provenance checks, and fail-loud handling of incomplete analysis before model loading.

IMPLEMENTED METHOD

- 1. Enumerate repository and model artifacts.
- 2. Parse supported serialization/model formats.
- 3. Apply AST, pattern, symbolic, taint-style, metadata, and provenance checks.
- 4. Reject unsafe dynamic-execution paths in the scanner itself.
- 5. Emit findings and fail-loud states for incomplete or unsafe analysis.

LIMITATIONS AND EVIDENCE BOUNDARY

- Static analysis does not prove model safety or generally detect neural-weight backdoors.
- Fixture detections are not population precision/recall; four benign samples do not establish a universal false-positive rate.
- Unsupported or incomplete analysis must remain explicit; no untrusted model code was executed in this verification.

SCOPED EVIDENCE

- Cited Python 3.12 CI: 241 passed, 1 skipped, 6 additional subtests; 75.67% statement coverage; 75% configured gate.
- Static inspection supports SafeTensors, GGUF, ONNX, Keras and pickle-derived artifacts, plus AST, symbolic, taint-style and dependency/provenance checks.
- Separate guarded offline harness: 12 attack fixtures + 18 variants + 3 large-artifact assertions detected; 4 benign samples produced no actionable findings. Network/subprocess calls were denied and report writing disabled.
- Fixture labels are incident-inspired regression data; external incident/CVE correctness was not independently authenticated.

REPRODUCTION

- git checkout 251a7b90fd60fa1884c643adda9d96cd7801abe6
- Install the documented development extras and run python -m pytest tests/ -q using the cited Linux CI configuration.
- A different platform or dependency set may produce different counts/coverage. This poster is not a promise about the latest main.

Dated tests and committed fixtures do not establish universal detection, production deployment or an SLO.